The NIST Guide For **Your Business**

March 2026

At TEC, our mission is to peel back the curtain on the technology that powers our daily lives and to turn complex technical concepts into practical, hands-on knowledge. We believe that true empowerment comes from understanding not just how to use your devices, but how to protect them, repair them, and master the digital environments we inhabit.

This guide is designed with that same "under the hood" philosophy. While the **NIST SP 800-171** standards are often viewed as a dense thicket of government jargon, they can be a vital blueprint for digital safety. By breaking NIST standards down into layman's terms and clear actions, we aim to bridge the gap between high-level policy and everyday application. This document serves as a convenient playbook to help your company improve its technical security.

Technology
Education
Collaborative

Table of Contents

Access Control....3
Awareness and Training....3
Audit and Accountability....4
Configuration Management (System-focused)....5
Identification and Authentication (User-focused)....5
Incident Response....6
Maintenance....6
Media Protection....7
Personnel Security....7
Physical Protection....8
Risk Assessment....9
Security Assessment and Monitoring....9
System and Information Integrity....11
Planning....11
System and Services Acquisition....12
Supply Chain Risk Management....13

Author

Ngoc T. Nguyen and Wyatt Johnson

Access Control

The "Who Goes There?" Rule

This section helps to ensure that only authorized individuals can enter your digital environment and perform specific, approved tasks.

Avoid using shared or generic login accounts for systems. Every user should have their own login and password for each system, and these details should not be shared among employees.

Users should only be able to access the tools, data, and information that are required to do their job effectively.

Assign the role of “Employee Accounts Manager” to a trusted employee within your business. This person will have the responsibility of disabling employee accounts (logins, etc.) when someone leaves the business, violates policies, etc., or those accounts are no longer needed. They will also be the sole person in the business with the authority to create new accounts and assign privileges to these accounts. This should be something that they double-check for accuracy once a week.

All users should log out of accounts when going to lunch, on a break, stepping away from their workstation, or at the end of the day.

Avoid granting business information access to users’ personal devices whenever possible, in case these devices are lost or stolen. If network access on users’ personal devices is required, encrypt the data on those devices.

Awareness and Training

The "Don't Click That Link" Rule

This section aims to inform anyone who has access to your system about what is expected of them and how to keep business information secure.

All users should receive training so they know the basic cybersecurity risks, such as phishing, weak passwords, or unsafe downloads, and how their actions can help keep data safe. Users must also learn what types of information are considered sensitive and how to handle, share, store, or delete that information properly. Users with special roles, such as “Employee Accounts Manager”, need deeper, more technical instruction tailored to their responsibilities.

Training should not be a one-time activity aimed only at new users. Instead, it should be refreshed monthly to keep everyone aware of new threats, updated tools, and new changes in business policies.

Everyone should know exactly how to report a possible security issue that they face, such as a suspicious email, lost device, or unauthorized access, so problems can be fixed quickly. There should be a clearly communicated path, such as reporting to your immediate manager or dedicated IT personnel.

Finally, your organization should work to build a culture of security awareness where protecting information is part of everyone's job. Leaders and managers should set an example, encourage good habits, and make it easy for employees to ask questions or get help when needed.

Audit and Accountability

The "Paper Trail" Rule

This section aims to ensure that your organization can monitor and understand what happens in the systems by keeping accurate records of user actions and system events.

Your organization needs to keep detailed records of what happens on your information systems so you can detect, understand, and respond to suspicious or unauthorized activity. This means turning on system logs that track user actions, security events, and important system changes. The goal is to make sure every significant action, such as logging in, accessing sensitive data, or changing configurations, can be traced back to a specific user or process.

These audit records must be stored safely so they cannot be altered or deleted without approval. Your organization should regularly review and analyze these logs to spot unusual patterns or security incidents. When something concerning is found, the information from the logs should be used to investigate and, if necessary, report the issue promptly.

To support accountability, systems should also provide alerts or notifications when critical events occur, such as failed login attempts or unauthorized data access. Overall, the goal is to help you understand how your systems are used, hold people accountable for their actions, and use audit information to strengthen security over time.

Configuration Management (System-focused)

The "Standard Setup" Rule

This section aims to ensure that information systems are set up, changed, and maintained in a secure and consistent way.

Your organization should control how hardware, software, and settings are configured so that unauthorized changes don't weaken the business's security. This includes establishing clear rules for approving and documenting all system changes, such as software updates and security patches. All new software installations need to be approved by either the head of your business or the person in charge of IT for your business.

Once everything is running smoothly, there should not be a need to frequently install new software programs in most businesses.

Your organization must keep an up-to-date list of all computer equipment and installed software to know exactly what is running and where it is located. This should be printed out on paper and stored in a safe location. Regular monthly reviews are encouraged to help detect unwanted or unexpected changes.

Systems should also use standard, approved configurations to reduce vulnerabilities. This means that devices have standardized settings that disable any unnecessary features or programs to help reduce potential backdoors for attackers. This will help maintain stability, prevent misconfigurations, and make sure every change supports the organization's security and compliance needs.

Identification and Authentication (User-focused)

The "Prove Who You Are" Rule

This section aims to ensure that only verified and authorized individuals and devices can access your organizational resources.

Your system should require that every user has a username and every system component has a unique device ID, so actions can be tracked and controlled. Before granting someone access to a resource, your organization must confirm their identity through secure methods.

We suggest that strong password policies should be enforced, so that all employees are using long (12+ characters) passphrases that are not easily guessed. Multi-factor authentication, such as Yubikey, should be used wherever possible, especially for remote or administrative access.

Your system must also protect stored authentication data, such as user logins and passwords, so they cannot be stolen or reused by attackers. Overall, the goal is to prevent unauthorized

access, ensure all activities can be traced to a specific identity, and reduce the risk of attackers impersonating legitimate users or devices.

Incident Response

The "Fire Drill" Rule

This section aims to ensure that your organization can quickly detect, report, and respond to security incidents before they cause serious damage.

Your organization should have a plan in place for what to do when something goes wrong, such as a cyberattack, data leak, suspicious activity, or system compromise. This plan should establish clear procedures for recognizing incidents, reporting them immediately, investigating the cause, containing the problem, and recovering normal operations. All teams should know their roles, communication paths, and responsibilities during an incident.

The organization as a whole must also keep records of incidents, lessons learned, and improvements made after an event. Regular training, testing, and updating of the incident response plan help ensure everyone is prepared. Overall, the goal is to minimize harm, restore security quickly, and continually strengthen defenses based on real-world experience.

Maintenance

The "Keep It Running" Rule

This section aims to ensure that all maintenance on systems, whether routine updates, repairs, or troubleshooting, is done securely, properly supervised, and only by authorized personnel.

Your organization should focus on the work performed to keep your systems functioning, which can introduce risks if tools, technicians, or external connections are not controlled. There must be well-documented information on who is allowed to perform maintenance, how their identity is verified, and what work was done.

If maintenance is performed by outside vendors or contractors, they must be supervised or follow strict security rules. Remote maintenance, such as support sessions or remote updates, must use approved, secure connections and be carefully monitored.

After any maintenance is complete, systems must be checked to ensure no unauthorized software, tools, accounts, or changes remain. Overall, the goal is to keep your system reliable while preventing maintenance activities from becoming a security weak point.

Media Protection

The "Lock the Drawer" Rule.

This section aims to ensure that any information stored on physical media, such as hard drives, USB flash drives, CDs, and printed documents, is properly protected.

Your organization should focus on preventing sensitive data from being accessed, copied, lost, or stolen when it is stored, transported, reused, or destroyed. Strict control must be placed on who can access the media, where it is kept, and how it is handled.

The key points here are:

- Sensitive media should be stored in secure locations, labeled appropriately, and protected from unauthorized use.
- When media needs to be moved, whether physically or electronically, it must be transported safely so it cannot be damaged or lost.
- Hard drives and USB flash drives should be wiped before re-use using specific tools made for the job, such as the Drive Wiping Station at the Advanced Cyber Systems Lab.
- Paper documents should be shredded and destroyed. Multiple vendors do this in a secure and verifiable way as a business.
- CDs should be physically destroyed before disposal.
- Printers and other network-attached devices need to be checked for hard drives before disposal.
- If you want more specific details on proper technique, please refer to NIST MP-06.

Overall, the goal is to make sure that data in the media remains protected no matter where it is stored or how it is handled.

Personnel Security

The "Background Check" Rule.

This section aims to address the human element in security by screening individuals before hiring and managing access throughout their employment.

Your organization should screen every individual before granting access to systems containing sensitive information.

The required steps are:

- Initial background checks to identify potential security risks or a history of misconduct.
- Re-evaluate access levels whenever an employee changes roles or departments.

- Disable all system access immediately upon an employee's termination or resignation.
- Collect all company-owned equipment, keys, and badges during the offboarding process.
- Establish a standard employee policy for any violation of security practices.
- Ensure employees understand their long-term responsibility to protect business information even after leaving the company.
- Review the data access and online behavior of staff members from work on a periodic basis.
- Maintain a clear record of who has been granted access to specific data sets.

Overall, it is highly recommended that security requirements be incorporated into the standard hiring and offboarding procedures.

Physical Protection

The "Guard The Gate" Rule.

This section aims to highlight the security of the office space and hardware using locks, badges, and monitoring to prevent unauthorized entry.

Your organization should define clear security perimeter layers around the office and data storage areas. These areas should have controlled entry and exit points using ID badges or electronic keycards.

Suggested steps are:

- Require all visitors to sign in and out of the facility.
- Escort visitors at all times to prevent unauthorized access to server rooms or workstations.
- Protect critical infrastructure like power lines and internet cables from tampering.
- Use cameras and motion sensors to monitor the building 24/7.
- Maintain physical access logs to track movement within sensitive areas.
- Secure laptop computers with cable locks when used in public areas.
- Ensure that all sensitive documents are not left visible on desks overnight and are locked in a drawer.

Overall, physical security acts as the first line of defense; if an intruder can touch a server, they can likely access it.

Risk Assessment

The "Know Your Weakness" Rule.

This section aims to elevate your organization's security in search of vulnerabilities in the system and evaluate potential threats to data on a regular basis.

Your organization should hunt for "holes" in the security posture before hackers find them. Security is not a static goal but a moving target, making it necessary to proactively look for weaknesses before attackers do. This process involves scanning the network for software "vulnerabilities" and analyzing how a threat might specifically impact the business. There are vendors who can provide this as a service, in addition to your own internal testing.

The key points here are:

- Regularly analyze the likelihood and potential impact of various cyber threats.
- Prioritize the fixing of the most dangerous security gaps first. Include "supply chain risk" by checking the security of software vendors.
- Update the risk assessment whenever significant changes occur in the network. Use the findings to justify the budget for new security tools or training.
- Document the entire assessment process to prove compliance with NIST standards.
- Review the threat landscape regularly to stay ahead of new hacking techniques.
- Treat risk management as a continuous cycle rather than a one-time project.

Overall, it is essentially a "health checkup" for the digital environment to ensure the most dangerous gaps are filled before hackers find them.

Security Assessment and Monitoring

The "Check Your Work" Rule.

This section aims to test security controls to verify they work as intended and document any needed improvements.

While some of the previous sections help build a defense, this one focuses on testing whether those defenses actually work. After the internal testing by your own team, your organization should have an independent third party try security tests on your business. Often, this includes "Penetration Testing," where an outside specialist simulates an attack to find hidden flaws that were missed in the internal testing. The goal of all this testing is to produce a "Plan of Action and Milestones" (POA&M) that documents what issues were found and sets a clear path for

making improvements. This process of testing, finding problems, and fixing these issues should be viewed as an ongoing cycle and not a “one-off and we are good” event.

When possible, re-test any fixed vulnerabilities to confirm the solution was effective.

Document the proof that security measures are active and functional.

Overall, it is essential to periodically test the effectiveness of all security controls and document a plan of action to address any identified weaknesses.

System and Communications Protection

The "Secure Pipes" Rule.

This section aims to safeguard data as it moves across networks and isolate sensitive systems from public-facing ones.

Data is most vulnerable when it is moving across the Internet or between offices. To protect this data, your organization should use strong encryption to scramble information into an unreadable format until it reaches its destination.

To do this:

- Use strong encryption to scramble data while it travels across the Internet. Look for “known good” encryption standards such as AES, RSA, or PGP.
- Separate internal networks from public websites using firewalls and different passwords to log in to each section.
- Manage encryption keys with strict controls to prevent unauthorized decryption.
- Terminate digital sessions automatically after a set period of inactivity.
- Prevent the system from displaying sensitive info on a screen for too long without user activity.
- Use secure protocols for all web-based communications (HTTPS, SFTP/FTPS, and SSH).

Your company should also define "internal boundaries", such as separating the public-facing part of the business (like a website) from the private servers and computers where sensitive data lives. By separating information with these boundaries, we can help prevent a hacker from easily getting from the website to this sensitive data.

Overall, it is essential to secure data during transmission using encryption and maintain clear boundaries between internal networks and public-facing systems.

System and Information Integrity

The "Health Check" Rule.

This section aims to keep your systems healthy by monitoring unauthorized changes and protecting against malware.

Your organization should strive to maintain "clean" systems since it is vital for preventing the spread of digital viruses and malware.

This can include:

- Install and maintain up-to-date antivirus and anti-malware software on every device. No antivirus software will catch everything, but it is a layer of security.
- Test and deploy software "patches" and system updates quickly to fix known security bugs.
- Monitor the system for any unauthorized access or suspicious changes to files.
- Configure alerts to notify the IT team or the head of the company when a potential threat is detected.
- Protect email systems from spam and malicious attachments. Consider moving away from email as much as possible for internal communications and transferring files.
- Verify the integrity of software before installing it on the network by downloading it from known sources and checking hash values when available.
- Block access to known malicious websites or IP addresses.
- Test to ensure that systems recover to a secure state after a crash, with their security settings back up and running.
- Do a bit of research to make sure that you are running the most secure computers, software, and related systems available within your budget.

Overall, it is essential to protect systems from malicious code and unauthorized changes through rapid software patching and continuous health monitoring.

Planning

The “Map The Mission” Rule

This section aims to develop and maintain comprehensive security plans to document how protected information remains safe.

Without a written strategy, security can become a series of disorganized reactions to bad events. Your organization should start work on a System Security Plan (SSP), which is a living document that describes the entire digital environment and every protective measure in place. It defines who is responsible for what systems and actions. This helps to ensure that security is

baked into the company's long-term goals. Having this plan in place allows the organization to remain consistent even as technology changes or employees move on.

Some suggested steps are:

- Review this security plan periodically to ensure it stays accurate as the business grows.
- Update the documentation whenever major changes occur in technology or company structure.
- Define the specific roles and responsibilities of personnel involved in data protection.
- Describe how this plan coordinates with other existing company policies.
- Share the plan only with authorized individuals who require it for their work duties.
- Protect the planning documents themselves from unauthorized access or theft.
- Ensure the plan identifies the financial and human resources needed for security.
- Keep a thorough record of all revisions and approvals for these documents.

Overall, it is essential to document a comprehensive system security plan that outlines all protective measures, roles, and resources required to safeguard information.

System and Services Acquisition

The “Vet the Tech” Rule

This section aims to manage the lifecycle of information systems by incorporating security requirements into the purchase and development process.

Security risks can enter an organization through the software or services purchased from others. Your organization should require that security be a major factor in the buying process, rather than just cost or convenience.

When hiring a cloud provider or buying a new database, responsible parties from your company must verify that the product was built using secure methods. It ensures that any new "tool" added to the toolbox doesn't come pre-loaded with vulnerabilities that could compromise the rest of the network.

Recommended steps are:

- Include specific security requirements in all requests for new software or hardware purchases.
- Document the security functions provided by every third-party service or product used.
- Require software developers to follow secure coding practices and provide proof of testing.
- Perform a thorough security review of all new systems before they are fully implemented.
- Manage the configuration of all systems throughout their entire functional life.

- Ensure that any external service providers meet the same strict security standards as internal teams.
- Limit the use of software that does not have a clearly defined support or update lifecycle.
- Monitor the delivery of new hardware to prevent tampering during the shipping process.
- Verify that new services do not introduce unknown vulnerabilities into the existing network.
- Maintain detailed documentation for all custom-built or modified system components.

Overall, it is essential to integrate security requirements into every stage of the lifecycle for purchased hardware, software, and third-party services.

Supply Chain Risk Management

The “Watch The Source” Rule

This section aims to highlight how your organization can identify and mitigate risks associated with the vendors and products used to handle sensitive information.

Modern businesses rely on a complex web of global vendors, and a single weak link can cause a total collapse. Your organization should focus on identifying risks within that chain, such as counterfeit hardware or software developed by untrustworthy foreign entities. It involves checking the "pedigree" of critical parts and ensuring that vendors follow their own strict security rules. By watching the source, the organization protects itself from "Trojan Horse" attacks where a threat is hidden inside a trusted product.

Suggested steps are:

- Establish a formal process to evaluate the security health of all technology vendors.
- Identify critical components within the supply chain that could impact data safety if compromised.
- Require vendors to disclose their own security practices and their process for reporting breaches.
- Monitor for signs of tampering or counterfeit parts in all received hardware.
- Evaluate the risks posed by suppliers owned or controlled by foreign entities.
- Include specific, mandatory security language in all vendor contracts and legal agreements.
- Create a backup plan to respond to supply chain disruptions or vendor failures.
- Perform periodic audits of key suppliers to ensure they maintain compliance over time.
- Maintain a list of approved vendors who have passed an internal security screening.
- Update the supply chain risk strategy regularly as new global threats emerge.

Overall, it is essential to evaluate and monitor the security practices of all vendors and suppliers to prevent the introduction of compromised or counterfeit products.